

# Security+ 4.6 · Identity & Access Management

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.6 — Identity & Access Management (12:46) · [vídeo original ↗](#) · [YouTube ↗](#)

IAM: account provisioning (create/config); RBAC (por função) e ABAC (por atributo); SSO (login único federado — SAML/OIDC); service account (credencial de script — gestão especial).

## Highlights que a prova cobra

- RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar
- SSO: login único — reduz reuso de senha (mais seguro)

## Dicas de prova

- 'access assigned based on job role'=RBAC

**Cenário clássico:** 'empregado de marketing só acessa arquivos da área de marketing'=RBAC.

## Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?  
**A)** Senha, PIN e resposta secreta  
**B)** Algo que sabe, algo que tem, algo que é  
**C)** 3 senhas diferentes  
**D)** Usuário, senha e e-mail

2. O serviço que controla QUEM pode acessar O QUÊ na nuvem (usuários, papéis, permissões) é o:

- A) CDN
- B) IAM
- C) VPN
- D) DNS

3. Qual protocolo de autenticação utiliza tickets e é amplamente usado em ambientes Active Directory?

- A) RADIUS
- B) TACACS+
- C) Kerberos
- D) LDAP

4. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B) Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar...
- C) Substituir controles técnicos preventivos por termos de adesão informais
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'SSO: login único — reduz reuso de senha (mais seguro)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B) Substituir controles técnicos preventivos por termos de adesão informais
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas
- D) Implementar a solução correspondente: SSO: login único — reduz reuso de senha (mais seguro)...

**6.** Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: "access assigned based on job role'=RBAC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'access assigned based on job role'=RBAC...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**7.** Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: "empregado de marketing só acessa arquivos da área de marketing'=RBAC.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'empregado de marketing só acessa arquivos da área de marketing'=RBAC....
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**8.** Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar...

**9.** Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'SSO: login único — reduz reuso de senha (mais seguro)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: SSO: login único — reduz reuso de senha (mais seguro)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10.** Cenário corporativo (Identity & Access Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'access assigned based on job role'=RBAC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'access assigned based on job role'=RBAC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

## GABARITO COMENTADO

- 1) B — Algo que sabe, algo que tem, algo que é.** MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA.
- 2) B — IAM.** IAM (Identity and Access Management) gerencia identidades e permissões. É onde você aplica menor privilégio na nuvem. CDN acelera conteúdo; DNS resolve nomes.
- 3) C — Kerberos.** Kerberos usa tickets (TGT e service tickets) para autenticação mútua em redes, sendo o padrão do Active Directory.
- 4) B — Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as du.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar. As demais alternativas configuram viol
- 5) D — Implementar a solução correspondente: SSO: login único — reduz reuso de senha (m.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): SSO: login único — reduz reuso de senha (mais seguro). As demais alternativas configuram violações grave
- 6) A — Implementar a solução correspondente: 'access assigned based on job role'=RBAC...** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): 'access assigned based on job role'=RBAC. As demais alternativas configuram violações graves de conformi
- 7) C — Implementar a solução correspondente: 'empregado de marketing só acessa arquivos.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): 'empregado de marketing só acessa arquivos da área de marketing'=RBAC.. As demais alternativas configura
- 8) D — Implementar a solução correspondente: RBAC por FUNÇÃO; ABAC por atributo — as du.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): RBAC por FUNÇÃO; ABAC por atributo — as duas formas de autorizar. As demais alternativas configuram viol
- 9) C — Implementar a solução correspondente: SSO: login único — reduz reuso de senha (m.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): SSO: login único — reduz reuso de senha (mais seguro). As demais alternativas configuram violações grave
- 10) C — Implementar a solução correspondente: 'access assigned based on job role'=RBAC...** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Identity & Access Management): 'access assigned based on job role'=RBAC. As demais alternativas configuram violações graves de conformi

